Document Title: SECURITY ASSESSMENT REPORT

Author: Data Science Lab. Rey Juan Carlos University, Spain.

Date: 2024/06/05

Version: 2.0

Project Number: 190123244

Project Acronym: VR-CARDIO

Project title: VISUALIZACIÓN DE BIOPOTENCIALES PARA EQUIPOS CARDIOLÓGICOS

Version	Date	Description of changes
1.0	2024/03/18	First version
2.0	2024/06/05	Add information from SPIKA TECH Cybersecurity MDR Extension document

Table of contents

1. Introduction 3
2. Data 3
2.1 Identity and Access Management (IAM) 3
2.2 Data confidentiality 3
2.3 Data minimization and segregation 3
2.4 Data processing consent and other rights of data subjects 4
2.5 Deletion of data 4
3. Infrastructure 5
3.1 Backups 5
3.2 Default settings 5
3.3 Availability measures 5
3.4 Development devices OS versions 5
4. Software development 5
4.1 Design principles 5
4.2 Updates management 5
4.3 Vulnerability analysis 6
4.4 Audit logs 6
5. Medical device security 6
6. APIs 6
6.1 WAF & DDoS protection 6
6.2 Authentication 7
6.3 Error code handling 7
7. Technical tests 7
8. Risk assessment and management 12
9. Documentation and post-market surveillance 12
9.1 Technical documentation and instructions for use 12
9.2 Post-market surveillance system 12
10. Cybersecurity guidelines, policies and procedures 13
11. Bibliography 14

1. Introduction

This document provides the main findings and the recommendations for addressing any identified vulnerabilities in the security controls associated with the VR-CARDIO project. The present assessment focuses on analyzing SPIKA TECH ("company") procedures and technical measures in place to comply the security of its information assets and infrastructure against cyber threats. By conducting this evaluation, the DSLAB, high-performance group of Foundations and Applications of Data Science, in the Rey Juan Carlos University (Spain), aims to provide the company with insights into its current security stance for enhancing its overall security posture.

The rest of the document is structured as follows: sections 2, 3, and 4 encompass the findings regarding the security evaluation for the Data, Infrastructure, and APIs, respectively. Section 5 includes additional resources that can assist the company in enhancing its cybersecurity measures for VR-CARDIO and regulatory compliance.

2. Data

This section will be focused on bringing the company performance on the General Data Protection Regulations. It will show the confidentiality and security of data according to the Portal Privacy Statement and the Regulation 2016/679 (General Data Protection Regulation).

The following issues have been checked.

2.1 Identity and Access Management (IAM)

The user management regarding the access to the web and desktop applications is properly managed using three different roles, with different levels of permissions associated to each of them:

1. **Administrator**: has access to all data, infrastructure resources and applications settings.
2. **Professional**: has access to all data, patients, and their associated DAS (Data Acquisition System). It can capture signals from the DAS.
3. **Student**: has access to limited aggregated data. It cannot capture signals from the DAS.

Within Google Cloud Platform (GCP), where the infrastructure is deployed, various roles with defined permissions regulate user actions. Additionally, access to GCP resources is restricted to a limited number of authorized users, reducing the risk of unauthorized access, and enhancing overall security.

It is important to always keep the principle of least privilege in mind, the company review these roles and modify if needs change at any time when new specific roles may become necessary.

2.2 Data confidentiality

This aspect is mainly related to encryption. Firebase Realtime Database is the service used for storing data. It uses SSL/TLS protocols to establish connections between clients and the database.

Communication with both the web application and the API is secured using the HTTPS protocol and SSL certificates, ensuring encrypted data transmission.

2.3 Data minimization and segregation

The company currently retrieves a high amount of special category personal data ('sensitive data'). It is important to follow the data minimization and data segregation principles:

- **Data minimization**: expressed in the Article 5 GDPR [1], means that "data controller

should limit the collection of personal information to what is directly relevant and necessary to accomplish a specified purpose. They should also retain the data only for as long as is necessary to fulfil that purpose. Data controllers should collect only the personal data they really need, and should keep it only for as long as they need it." [2].

- **Data segregation**: refers to the process of separating certain sets of data from other data sets so that different access policies can be applied to those different data sets. The goal of doing so is only allowing the individuals who are authorized to view certain data sets access to them.

Currently, all these variables related to personal data from patients are:

- ID (hash of name and date of birth)
- Name and surname
- Age
- Genre
- Telephone number
- Weight
- Height
- Abdominal diameter
- Chest diameter
- Physical condition
- Previous diseases
- Previous treatments
- Somatotype

DSLAB and the company have determined that all the data is strictly necessary for the product purposes. In addition, data are stored separating sensitive data, this allows only users who strictly require access to personal data to have it.

2.4 Data processing consent and other rights of data subjects

The processing of special categories of personal data is expressed in the Article 9 GDPR. It states that the processing of genetic data and data concerning health shall be prohibited, except if, among others, the data subject has given explicit consent to the processing of those personal data for one or more specified purposes.

In the case of the VR-CARDIO project, some data are retrieved by partner hospitals. The roles of data controller and processor are properly defined by the company. The company and the hospitals are joint controllers, they design and use a common platform for shared purposes.

The company possess the documents of consent. DSLAB recommendation is fully included on their consent method. The consent includes data subjects' rights of access, rectification, erasure, restriction of processing, data portability, etc.

2.5 Deletion of data

Currently, there is an established retention period for the personal data gathered by professionals and DAS. The guidelines of this period are showed in the documents signed by the hospital and patients.

3. Infrastructure

3.1 Backups

A daily backup protocol is implemented for the Firebase Realtime Database, ensuring the preservation of data integrity and security. Access to these backups is restricted to authorized personnel, specifically developers and administrators, to maintain strict control over data handling and safeguard against unauthorized access.

3.2 Default settings

All default configurations of Google Cloud Platform services are thoroughly reviewed and modified. This proactive approach ensures that all services are configured optimally, minimizing potential security risks and vulnerabilities while maximizing performance and efficiency.

3.3 Availability measures

The availability aspect is also effectively managed through the implementation of Cloud Functions and Cloud Run technologies. This strategic utilization of serverless architectures over traditional infrastructures enhances scalability, reliability, and cost-effectiveness in ensuring uninterrupted access to the system's resources. Access to these resources is optimized, allowing for dynamic scaling based on demand, thus minimizing downtime, and optimizing resource allocation.

3.4 Development devices OS versions

The OS of devices used for the development of the applications and other software meet the following minimum requirements regarding versions:

- Windows: Windows 10 Pro or Enterprise.
- macOS: Catalina or later.
- Linux: Ubuntu 20.04 LTS or later

These OS versions were all initially released before 2020. The latest version of macOS Catalina dates from July 20, 2022, and four new versions of the OS have been released since then. Standard support for Windows 10 and Ubuntu 20.04 will end in October 2025 and April 2025, respectively. However, the most critical security concern is not the major OS version, but the specific releases and security patches installed on the device. The company controls the update management process for these devices, potentially leaving them without vulnerabilities dating back several years, thereby reducing the likelihood of easy exploitation. Moreover, the company have installed firewall protection in the devices that help to protect them.

4. Software development

4.1 Design principles

The company follow “security by design” principles throughout every stage of the device lifecycle, including the management of security activities, specification of security requirements, secure implementation, security verification and validation through testing, the management of security-related issues, security updates and patches management, and offering security guidelines in documentation.

Unit tests are included in deployment phase, ensuring process integrity, default handling, output accuracy and performance. Both black box testing on inputs and white box testing on the internal structure of modules are also carried out.

4.2 Updates management

There are version control tools for managing dependencies in the web application's code. However, while the Unity code itself doesn't rely on external dependencies, it uses libraries whose

versions are consistently verified.

4.3 Vulnerability analysis

The company development team have vulnerability analysis tools to control their development processes. They have static and dynamic analysis tools, recognizing the importance of comprehensive vulnerability assessment to enhance the security posture of their software products.

4.4 Audit logs

The company maintains comprehensive audit logs to track and monitor all activities within their systems and applications. These audit logs capture a wide range of events, including user access, system modifications, and data transactions, providing a detailed record of system activities for ensuring the principles of auditing and non-repudiation.

5. Medical device security

The medical device is equipped with the following security capabilities that protect it and ensure secure communication:

- **Automatic logoff**: ensures that the session automatically logs off after a period of inactivity, reducing the risk of unauthorized access.
- **Audit controls**: conducting internal audits based on cybersecurity ISOs to check that they are being properly complied with.
- **Authorization**: establish mechanisms to ensure that only authorized users can access and perform certain actions on the device, based on specific roles and permissions.
- **Configuration of security features**: having access to be able to modify cybersecurity features.
- **Cybersecurity product upgrades**: ensure the capability to update the software and firmware to fix vulnerabilities and enhance defenses against new threats.
- **Data backup and disaster recovery**: implement mechanisms for backing up data and recovery procedures to restore software functionality after failures or security incidents.
- **Emergency access**: provide methods for accessing the software in emergency situations, ensuring that access is controlled and properly logged.
- **Integrity and authenticity of personal data**: ensure that personal data is not altered or tampered with, maintaining its integrity and authenticity.
- **Malware detection and protection**: implement solutions to detect and prevent malware infection on the device, protecting its functionality and stored data.
- **Node and person authentication**: ensure that both devices and individuals interacting with the system are properly authenticated, preventing unauthorized access.
- **System and OS hardening**: apply security practices and configurations to strengthen the operating system and system components, reducing attack surfaces.
- **Security and privacy guides**: provide clear and understandable documentation on how to use and maintain the software's security and privacy features.
- **Confidentiality of data storage and transmission**: ensure that stored and transmitted data is encrypted and protected against unauthorized access, maintaining its confidentiality.

6. APIs

6.1 WAF & DDoS protection

Cloudflare operates by default in front of its Firebase service, in GCP infrastructure. Configuration is reviewed in order to get a good performance on services like Cloudflare, activating its WAF and DDoS protection, among other security features. Additionally, the proper configuration of GCP

services is reviewed and verified.

6.2 Authentication

The API authentication process employs an access token and a refresh token, each with a maximum validity period of 5 minutes. Access tokens are utilized to authenticate and authorize requests made to the API, granting temporary access to specific resources or functionalities. Meanwhile, refresh tokens are used to obtain new access tokens once they expire, extending the user's authenticated session without requiring reauthentication. This token-based authentication mechanism enhances security by minimizing the lifespan of tokens, thereby reducing the window of opportunity for unauthorized access or misuse.

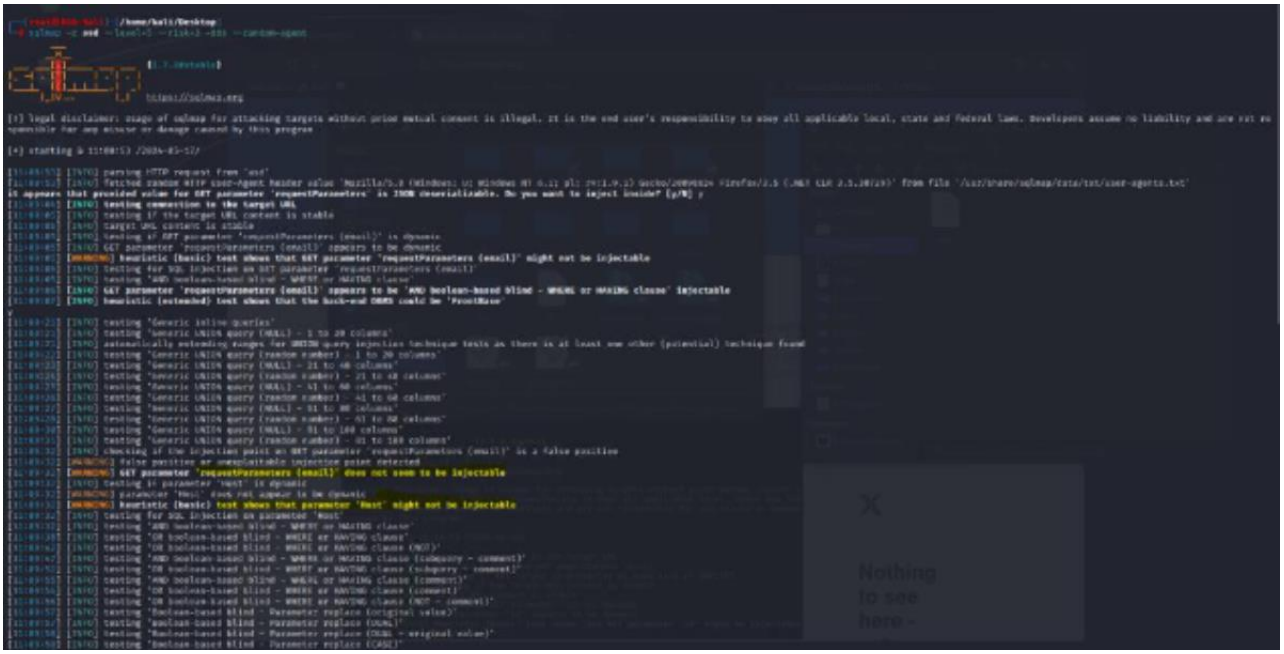
6.3 Error code handling

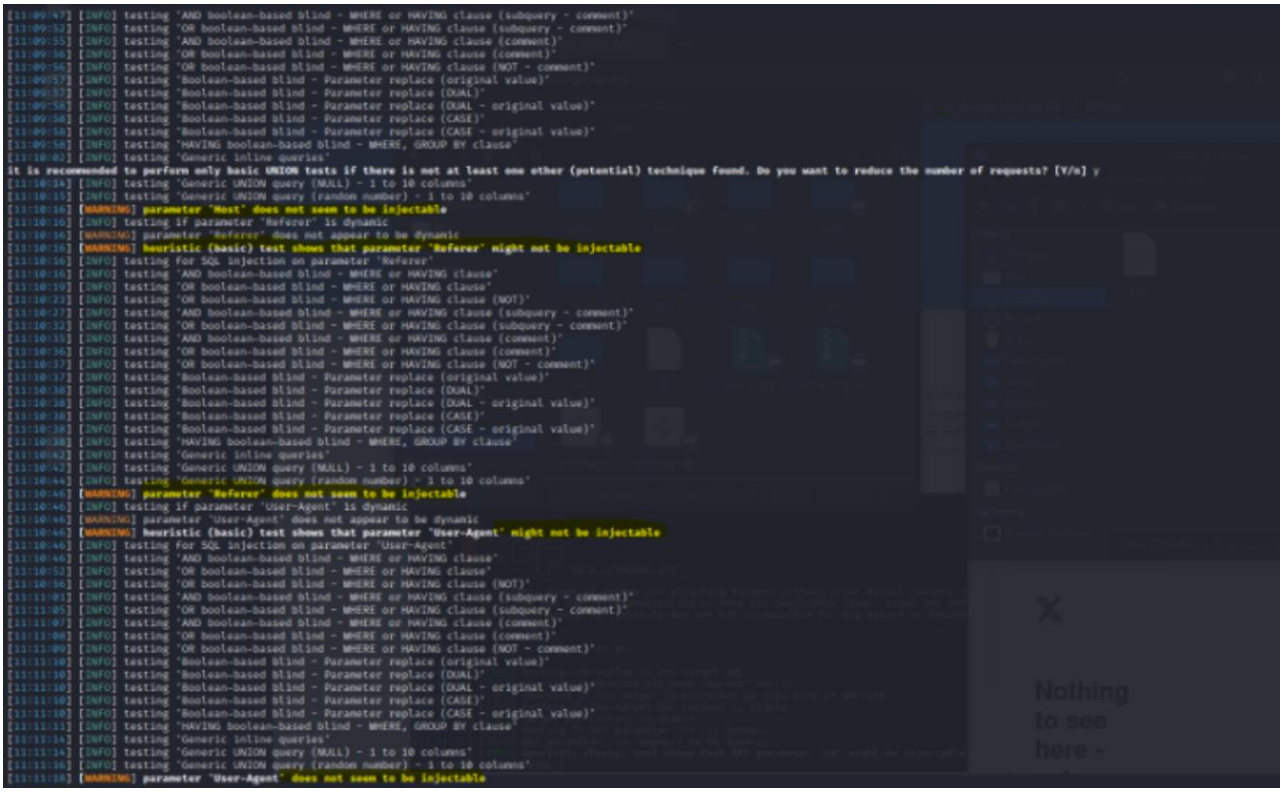
The API is designed to return appropriate error codes based on the type of error encountered, ensuring that responses contain only the minimal and essential information regarding versions, products, etc., from a security standpoint. This approach helps to prevent the leakage of sensitive information that could be exploited by potential attackers. By providing tailored error codes, the API enhances security by enabling clients to identify and address issues more effectively while minimizing the risk of exposing unnecessary details that could be leveraged to compromise the system.

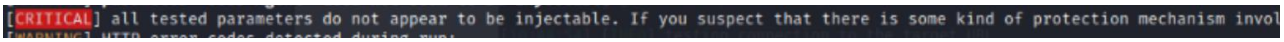
7. Technical tests

In order to check the appropriate cybersecurity of VR-Cardio, a series of technical tests have been carried out to check the functionality and security of the software:

First of all, an SQL Injection test has been done using the powerful tool of sqlmap with the following results:

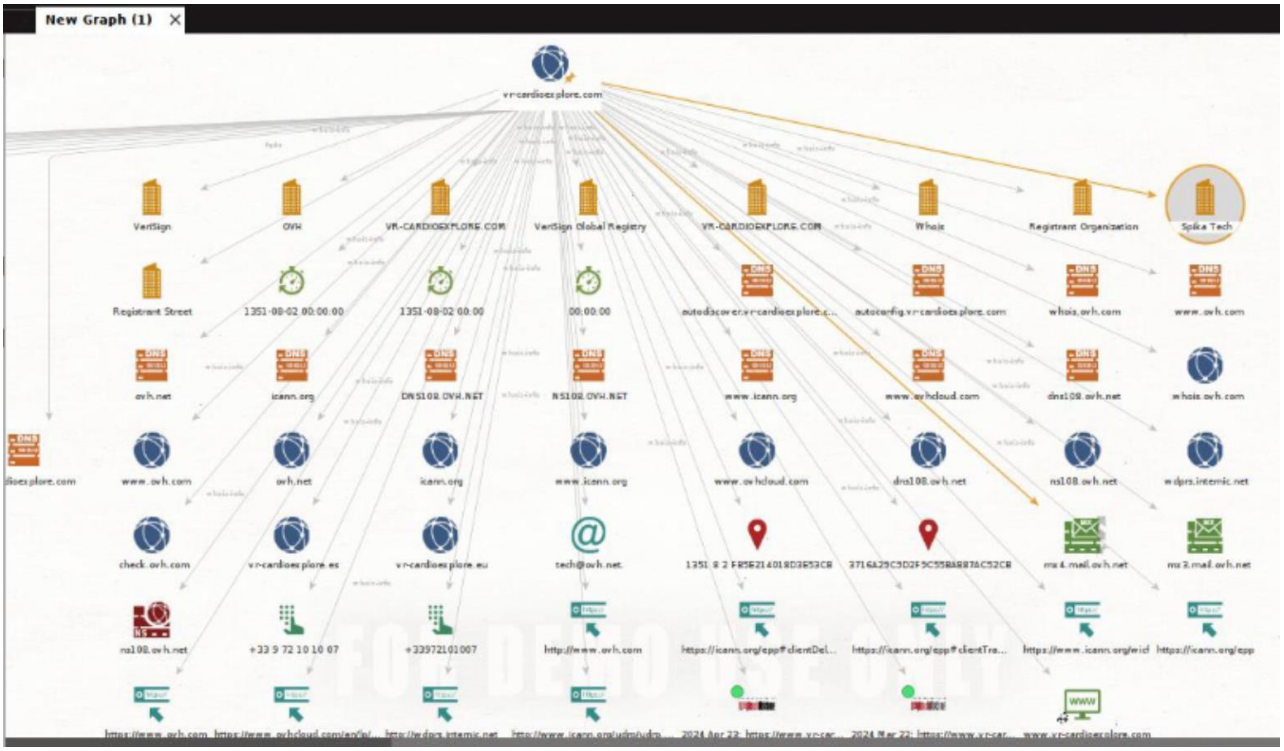






This is showing us the robust SQL protection according to this potential vulnerability.

Furthermore, more tests have been carried out. One of them is the powerful app Maltego (which shows how VRCardio could be exposed), this app gave the following result:



This app can't get any sensitive data from the domain. The test shows that there are no personal IP, employee's address etc.

Another powerful technique can be used to get the database info from the website. Once the URL endpoint is detected through the HTTP request a brute force technique can be applied to get the data from the URL.

Try with multiple URLs:

Users:

https://vrcardioexplorer-default-rtdb.europe-west1.firebasedatabase.app/users.json

```
{
  "error": "Permission denied"
}
```

Patients:

https://vrcardioexplorer-default-rtdb.europe-west1.firebasedatabase.app/patients.json

```
{
  "error": "Permission denied"
}
```

Profiles:

https://vrcardioexplorer-default-rtdb.europe-west1.firebasedatabase.app/profiles.json

```
{
  "error": "Permission denied"
}
```

There also no references to external scripts loaded on the website. This characteristic influence positively on the security. All the connections and influences of the website are controlled on the client and API hosted by the company.

Regarding the petitions on the study have found that many of the API calls are blocked and secured to external intrusion:

History | Search | Alerts | Output | Spider | Active Scan | WebSockets | AJAX Spider

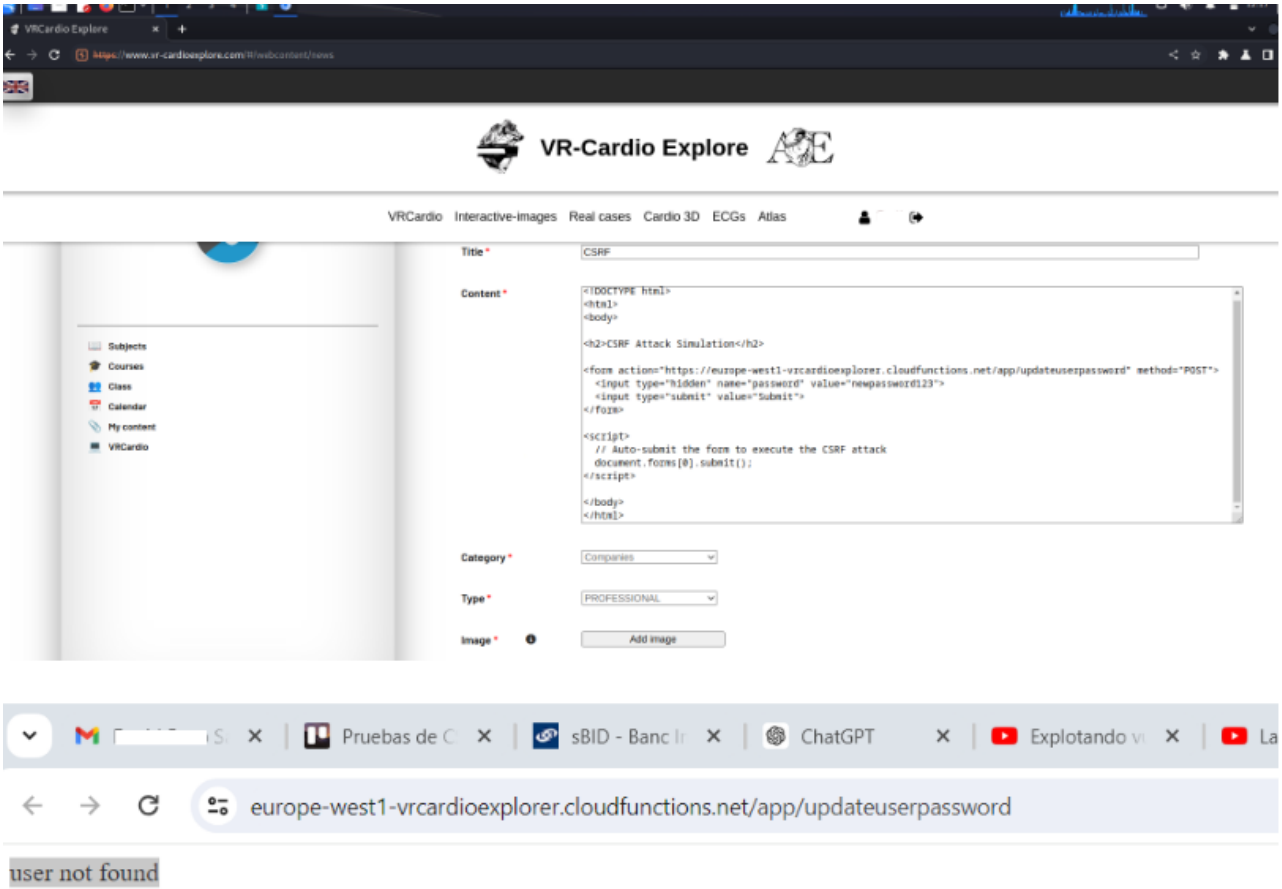
New Scan | Crawled URLs:69 | Export

Processed	Id	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Highest Alert
Out of Scope	515	5/16/24, 4:22:03 PM	GET	https://location.services.mozilla.com/v1/country?...	403	Forbidden	0 ms	130 bytes	40 bytes	
Out of Scope	516	5/16/24, 4:22:04 PM	POST	https://shavar.services.mozilla.com/downloads?c...	403	Forbidden	0 ms	130 bytes	40 bytes	
Out of Scope	517	5/16/24, 4:22:04 PM	GET	https://firefox.settings.services.mozilla.com/v1/b...	403	Forbidden	0 ms	130 bytes	40 bytes	
	518	5/16/24, 4:22:05 PM	GET	https://www.vr-cardioexplore.com/	200	OK	175 ms	577 bytes	6,877 bytes	Medium
Out of Scope	519	5/16/24, 4:22:05 PM	GET	https://fonts.googleapis.com/css2?family=Barlo...	403	Forbidden	0 ms	130 bytes	40 bytes	
Out of Scope	520	5/16/24, 4:22:05 PM	GET	https://firefox.settings.services.mozilla.com/v1/b...	403	Forbidden	0 ms	130 bytes	40 bytes	
	521	5/16/24, 4:22:05 PM	GET	https://www.vr-cardioexplore.com/styles.ad258...	200	OK	49 ms	577 bytes	184,067 bytes	Low
	522	5/16/24, 4:22:05 PM	GET	https://www.vr-cardioexplore.com/runtime-es20...	200	OK	60 ms	584 bytes	18,042 bytes	Low
	523	5/16/24, 4:22:05 PM	GET	https://ajax.googleapis.com/ajax/libs/jquery/3.3....	200	OK	126 ms	944 bytes	86,927 bytes	Medium
	529	5/16/24, 4:22:05 PM	GET	https://www.vr-cardioexplore.com/polyfills-es20...	200	OK	32 ms	584 bytes	199,310 bytes	Low
	530	5/16/24, 4:22:05 PM	GET	https://www.vr-cardioexplore.com/main-es2017...	200	OK	893 ms	584 bytes	879,253 bytes	Low
	531	5/16/24, 4:22:05 PM	GET	https://www.vr-cardioexplore.com/vendor-es20...	200	OK	1.24 s	585 bytes	5,376,325 bytes	Low
	532	5/16/24, 4:22:05 PM	GET	https://www.vr-cardioexplore.com/scripts.58b0...	200	OK	2.37 s	585 bytes	7,240,506 bytes	Low
	533	5/16/24, 4:22:11 PM	GET	https://www.vr-cardioexplore.com/favicon.ico	200	OK	38 ms	566 bytes	235,582 bytes	
	534	5/16/24, 4:22:11 PM	GET	https://www.vr-cardioexplore.com/node_module...	200	OK	62 ms	584 bytes	513,624 bytes	
Out of Scope	535	5/16/24, 4:22:11 PM	GET	https://europe-west1-vrcardioexplorer.cloudfunc...	403	Forbidden	0 ms	130 bytes	40 bytes	
Out of Scope	536	5/16/24, 4:22:11 PM	GET	https://jsonip.com/	403	Forbidden	0 ms	130 bytes	40 bytes	
	537	5/16/24, 4:22:11 PM	GET	https://www.vr-cardioexplore.com/assets/i18n/e...	200	OK	27 ms	569 bytes	67,158 bytes	

Alerts 0 4 5 4 Main Proxy: localhost:8080 ZAP out of date! Current Scans 0

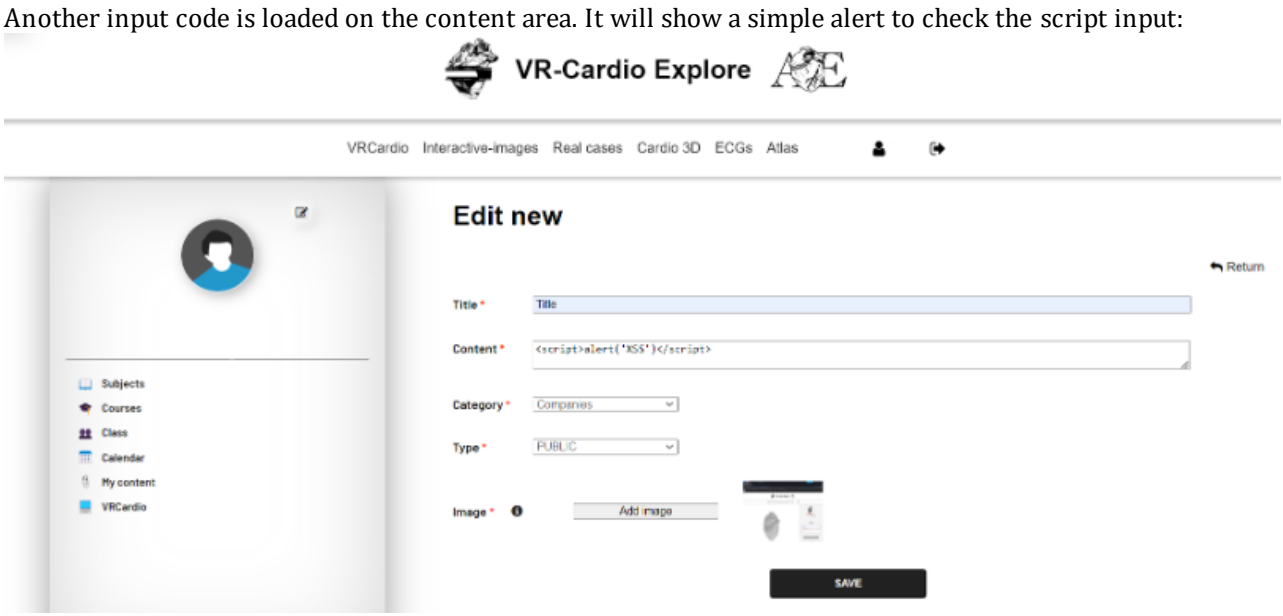
Other critical point has been addressed on the CSRF and XSS tests. Once logged in (using a common user with no extra privileges) a script has been developed trying to change a field of the profile.

```
<!DOCTYPE html>
<html>
<body>

<h2>CSRF Attack Simulation</h2>

<form action="https://europe-west1-vrcardioexplorer.cloudfunctions.net/app/updateuserpassword" method="POST">
  <input type="hidden" name="password" value="newpassword123">
  <input type="submit" value="Submit">
</form>

<script>
  // Auto-submit the form to execute the CSRF attack
  document.forms[0].submit();
</script>

</body>
</html>
```



The profile didn't change using the script and trying to change multiple parts and calls.

Another input code is loaded on the content area. It will show a simple alert to check the script input:



The intercepted message show how the script is not executed and is formatted correctly.

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Request to https://europe-west1-vrcardioexplorer.cloudfunctions.net:443 [216.239.36.54]

Forward Drop Intercept is on Action Open browser

Pretty Raw Hex

```
1 OPTIONS /app/getnew HTTP/2
2 Host: europe-west1-vrcardioexplorer.cloudfunctions.net
3 Accept: */*
4 Access-Control-Request-Method: POST
5 Access-Control-Request-Headers: content-type
6 Origin: https://www.vr-cardioexplore.com
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/110.0.5481.78 Safari/537.36
8 Sec-Fetch-Mode: cors
9 Sec-Fetch-Site: cross-site
0 Sec-Fetch-Dest: empty
1 Referer: https://www.vr-cardioexplore.com/
2 Accept-Encoding: gzip, deflate
3 Accept-Language: en-US,en;q=0.9
```

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extensions Learn

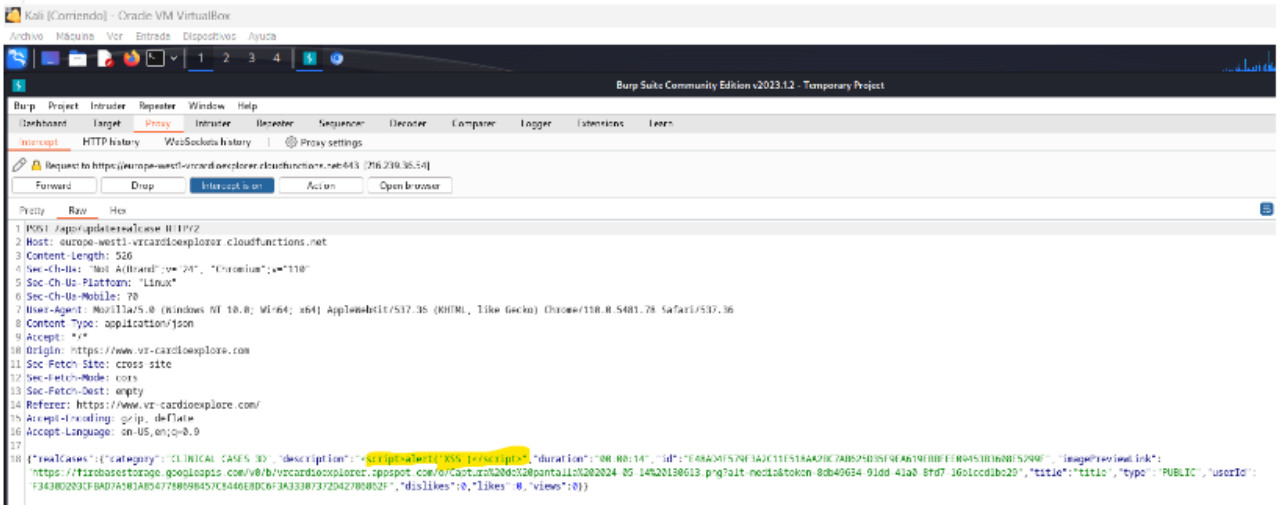
Intercept HTTP history WebSockets history Proxy settings

Request to https://europe-west1-vrcardioexplorer.cloudfunctions.net:443 [216.239.36.54]

Forward Drop Intercept is on Action Open browser

Pretty Raw Hex

```
1 POST /app/getnew HTTP/2
2 Host: europe-west1-vrcardioexplorer.cloudfunctions.net
3 Content-Length: 82
4 Sec-Ch-Ua: "Not A(Brand";v="24", "Chromium";v="110"
5 Sec-Ch-Ua-Platform: "Linux"
6 Sec-Ch-Ua-Mobile: ?0
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/110.0.5481.78 Safari/537.36
8 Content-Type: application/json
9 Accept: */*
10 Origin: https://www.vr-cardioexplore.com
11 Sec-Fetch-Site: cross-site
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://www.vr-cardioexplore.com/
15 Accept-Encoding: gzip, deflate
16 Accept-Language: en-US,en;q=0.9
17
18 {"news":{"id":"674B64935C0E45F10875EB785D3487CD584114B9F7F68FB5DE042D02BA5C5A6E"}}
```



The result is always a bad request after sending multiple petitions to the repeater using different data. VRCardio doesn't read the malicious code.

No execution on the search input fields around the multiple areas of VRCardio app and website.

Subsequently, based on the intercepted requests, several security-related aspects can be observed in the requests:

- **Secure Token:** A secure token is being requested (returnSecureToken: true), which is a best practice to ensure that the authentication token is generated and transmitted securely.
- **HTTPS:** The request is being sent via HTTPS (HTTP/2), indicating that the communication is encrypted. This provides an additional layer of security to protect the data during transmission.
- **Allowed Origins:** The request includes the Origin header, indicating that it is being made from the website https://www.vr-cardioexplore.com. This is important for CORS policies, helping to restrict access to specific origins only.
- **Sec-Fetch-Site and Sec-Fetch-Mode:** These headers are part of the Fetch specification in JavaScript and are used to indicate the context of the request. In this case, Sec-Fetch-Site indicates that the request is cross-site, while Sec-Fetch-Mode specifies that it is a CORS request. This is important for browser security policies.

8. Risk assessment and management

The company, within the VR-CARDIO project, follows a security risk management process, which is aligned with the overall risk management process for medical devices. It ensures that all aspects of both security and safety are addressed in a systematic and consistent manner. This process follows the typical steps in risk management: analysis, evaluation, control, evaluation of residual risk and reporting.

The analysis focuses on identifying potential security threats and vulnerabilities that could affect the medical device. The risk evaluation consists of determining the risk significance, estimating impact likelihood and severity. The control step implements measures to mitigate or avoid risks whose probability of severity is unacceptable, reducing them to tolerable levels. The evaluation of residual risks involves assessing the remaining risks to ensure they are within acceptable levels, while the reporting phase involves documenting all the previous steps.

For the risk evaluation phase, the company follows a security risk assessment process, involving the following steps: define scope and context, identify critical assets and resources, analyze threats, assess vulnerabilities, analyze impacts, determine likelihood, prioritize risks, define mitigation strategies and implement control. This process is carried out while continuous monitoring for new threats and vulnerabilities, and risk assessments are performed both periodically and after significant changes in the device or its operational environment. All the risk assessment steps involve the documentation and appropriate reporting to stakeholders and auditors.

9. Documentation and post-market surveillance

9.1 Technical documentation and instructions for use

The company provides both technical documentation and instructions for use. The first one includes details on how the device meets cybersecurity requirements and is updated regularly to reflect post-market surveillance findings, while the second provides guidance on maintaining device security, such as minimum hardware requirements, security measures or steps for keeping the device in a secure manner.

9.2 Post-market surveillance system

The company operates a surveillance system to monitor security incidents and vulnerabilities (stated on the ISO 13485). It collects and evaluates information on reported security incidents, monitoring user reports, vulnerability databases and security publications. After prioritizing

corrective actions, arising from the previous task, the system implements quick fixes and software updates as needed to mitigate risks, while developing other permanent solutions. Lastly, the system maintains clear and effective communication with software operators about potential risks and mitigation measures, providing guidance and support for implementation of updates and other necessary security actions.

10. Cybersecurity guidelines, policies and procedures

The company has defined some guidelines, policies and procedures regarding cybersecurity that all departments are responsible to follow.

- **Security policies and procedures**: establish and maintain clear policies and procedures that define how security aspects are managed within the company. These is reviewed and updated regularly to ensure their relevance and effectiveness.
- **Access control**: implement mechanisms to ensure that only authorized personnel have access to critical systems and data. This includes identity and access management (IAM), multi-factor authentication (MFA), and secure password policies.
- **Network security**: protect the company's network infrastructure through the use of firewalls, intrusion detection and prevention systems (IDS/IPS), and network segmentation to minimize the impact of potential breaches.
- **Endpoint security**: ensure that all endpoint devices, such as computers, mobile phones, and tablets, are protected against threats by using antivirus software, personal firewalls, and automatic update policies.
- **Data protection**: implement measures to ensure that sensitive data is protected both in transit and at rest. This includes the use of encryption, role-based access control, and data retention policies.
- **Incident response**: develop and maintain an incident response plan that outlines the steps to be taken in the event of a security breach. This includes identification, containment, eradication, and recovery from incidents, as well as communication with stakeholders.
- **Security awareness training**: provide ongoing training to all employees on best security practices and how to recognize and report potential threats. This is crucial for building a security-conscious culture within the company.
- **Vulnerability management**: establish a process to identify, evaluate, and mitigate vulnerabilities in systems and applications. This includes regular vulnerability scans and penetration testing.
- **Compliance and legal requirements**: ensure that all security operations comply with applicable laws and regulations. This includes compliance with regulations such as ISO 27001 and ENS.
- **Third-party risk management**: evaluate and manage risks associated with external vendors and partners. This includes conducting security assessments and establishing contractual agreements that define security expectations.
- **Physical security**: protect the company's physical facilities through the use of access controls, surveillance, and other security measures to prevent unauthorized access and damage to assets.
- **Monitoring and logging**: implement monitoring and logging systems to detect and analyse suspicious activities on the network and systems. This includes the use of SIEM (Security Information and Event Management) tools.
- **Business continuity and disaster recovery**: develop and maintain business continuity and disaster recovery plans to ensure the company's ability to operate during and after a security incident.

- **Secure software development**: integrate security practices into the software development lifecycle (SDLC) to ensure that applications are designed and built with security in mind from the outset.
- **Governance and oversight**: establish a governance framework that defines roles and responsibilities for information security management, ensuring proper oversight and accountability.
- **Continuous improvement**: foster a culture of continuous improvement in security practices by regularly reviewing policies, procedures, and controls, and adopting new technologies and approaches as needed.

11. Bibliography

[1] European Union, "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC," EUR-Lex, 2016.

[2] European Data Protection Supervisor, "Glossary > D," 22 March 2024. [Online]. Available: https://www.edps.europa.eu/data-protection/data-protection/glossary/d_en.

[3] Agencia Española de Protección de Datos, "Listas de tipos de tratamientos de datos que requieren Evaluación de Impacto relativa a Protección de Datos (art 35.4)," 2019.

[4] Agencia Española de Protección de Datos, "Evalúa_Riesgo RGPD," 22 March 2024. [Online]. Available: https://evalua-riesgo.aepd.es/.

[5] Agencia Española de Protección de Datos, "Gestión del riesgo y evaluación de impacto en tratamientos de datos personales," 2021.

[6] Center for Internet Security, "CIS Google Cloud Computing Platform Benchmarks," 22 March 2024. [Online]. Available: https://www.cisecurity.org/benchmark/google_cloud_computing_platform.

[7] Center for Internet Security, "Downloads," 22 March 2024. [Online]. Available: https://downloads.cisecurity.org/.

[8] Prowler, Inc., "Prowler," 22 March 2024. [Online]. Available: https://github.com/prowler-cloud/prowler.

[9] OWASP Foundation, "OWASP Application Security Verification Standard," 28 October 2021. [Online]. Available: https://owasp.org/www-project-application-security-verification-standard/. [Accessed 22 March 2024].